



System Security Week 5

Cross-Site Scripting (XSS)

Learning Outcomes

In this lab, you will:

- Learn basics of Cross-Site Scripting
- Learn how to avoid the Cross-Site Scripting attacks
- How attackers insert malicious code into poorly validated input fields
- How the attackers disrupt the normal behaviour of the applications

Introduction

Cross-Site Scripting (XSS) is basically a type of code injection made possible by incorrectly validating user input data, which usually gets inserted into the page through a web form or hyperlink. This code is injected in order to save some harmful data on the server or perform some malicious activity. In this lab we will go through some of the XSS examples, and will try to exploit them .

Tasks 1 Cross-site-Scripting - Reflected (GET)

- 1.1 Let's launch the bWAPP and log in with the credentials username: bee and password: bug. Leave the security level set to low for now, as can be seen in Figure 1.

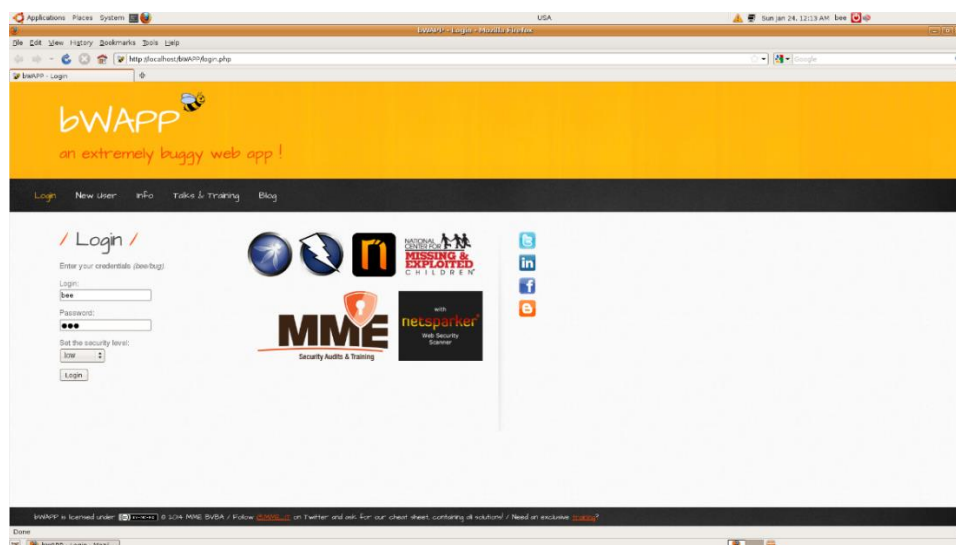


Figure 1 Login to the bWAPP

- 1.2 Now that you have successfully logged in, we are ready to exploit some bugs. Now from the list select 'Cross-site-Scripting - Reflected (GET)' and click hack button as can be seen in Figure 2.

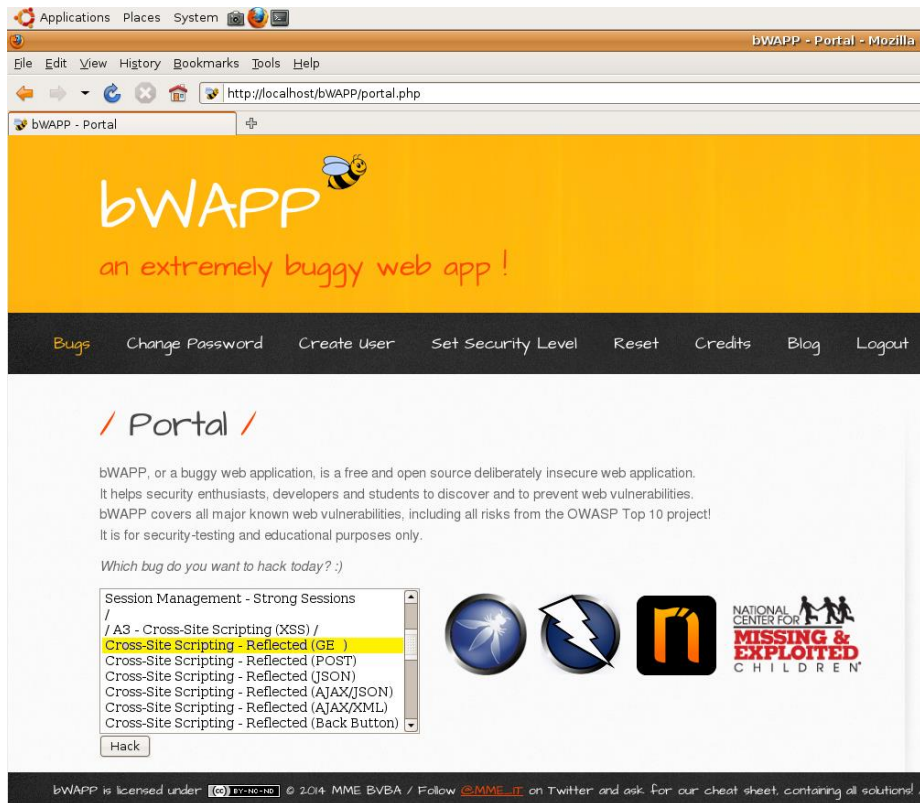


Figure 2 Selecting XSS reflected (GET)

You should now see a form as shown in Figure 3.

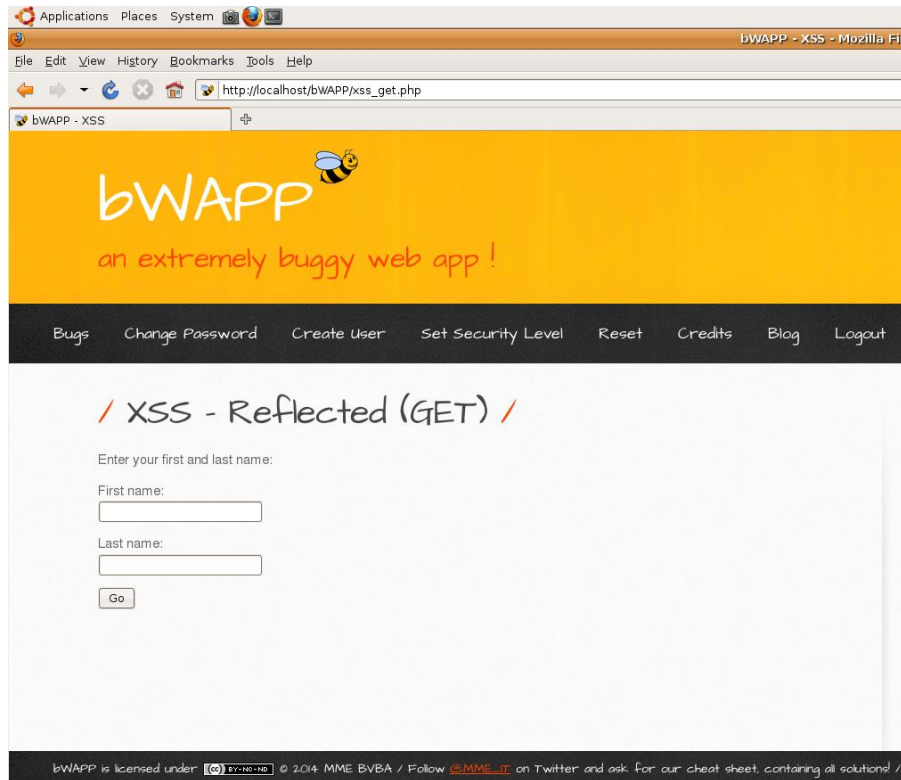


Figure 3 Name form

1.3 The valid input to the form could be a first name and last name as can be seen in Figure 4.

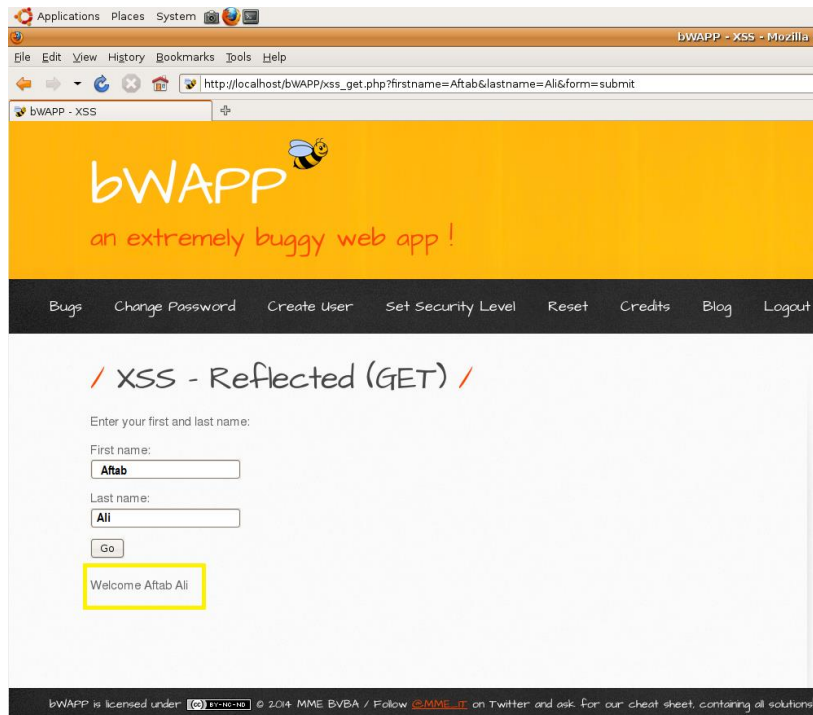


Figure 4 login with valid credentials

1.4 Now we can inject some XSS code into the form. Both the input boxes are vulnerable to XSS. Enter the following payload into the first name field and any arbitrary text or numbers in the last name field as shown in Figure 5: `<script>alert('Hacked')</script>`

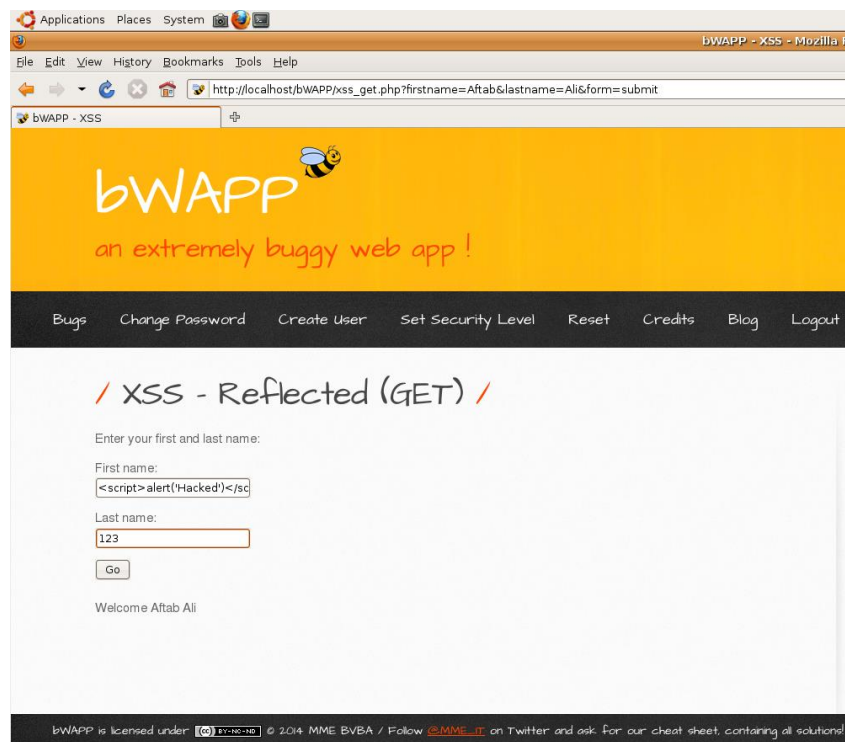


Figure 5 Entering the query

1.5 Submit the above form by clicking the Go button. You will see an alert displayed on the page with a text 'Hacked'.

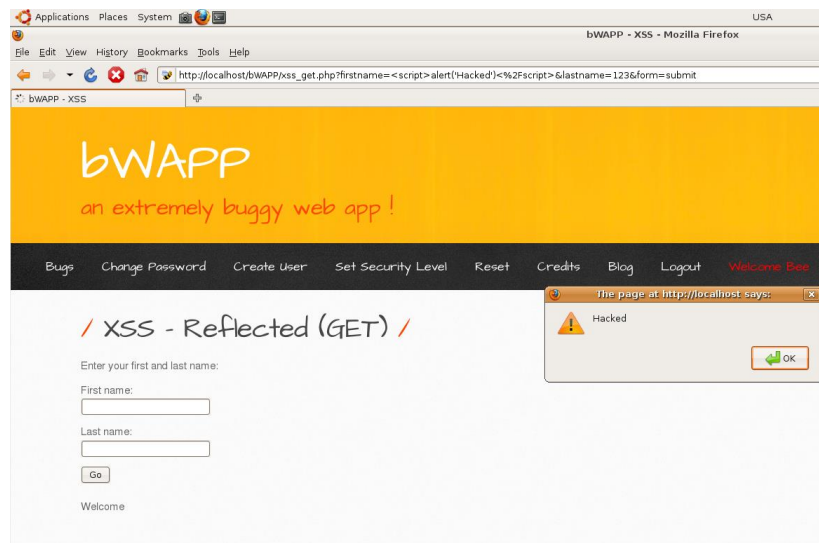


Figure 6 XSS hacked

Tasks

Now answer the following questions on your worksheet:

- What happened when you entered the script?
- Repeat this process for XSS Reflected (POST)



Figure 7 XSS Reflected (POST)

Now we will do this for Cross-site-Scripting - Reflected (JSON):

When you provide the valid movie name in the search box, it will give you the output as shown in the image below:

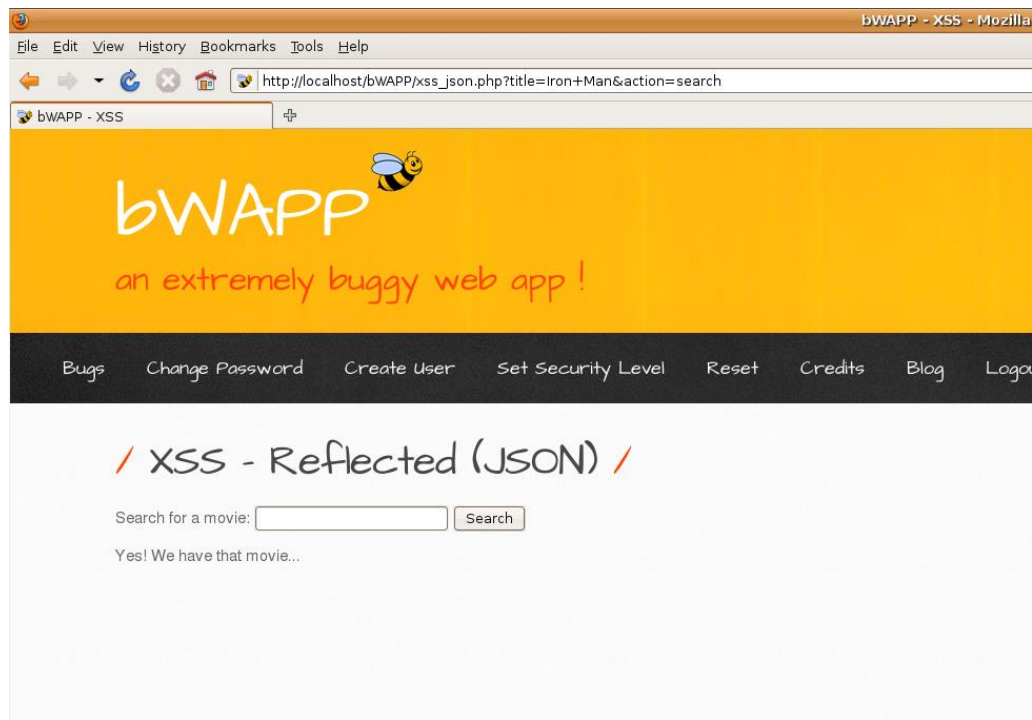


Figure 8 XSS Reflected (JSON)

The response of the web app will just be printed out by the JavaScript in the JavaScript tag.

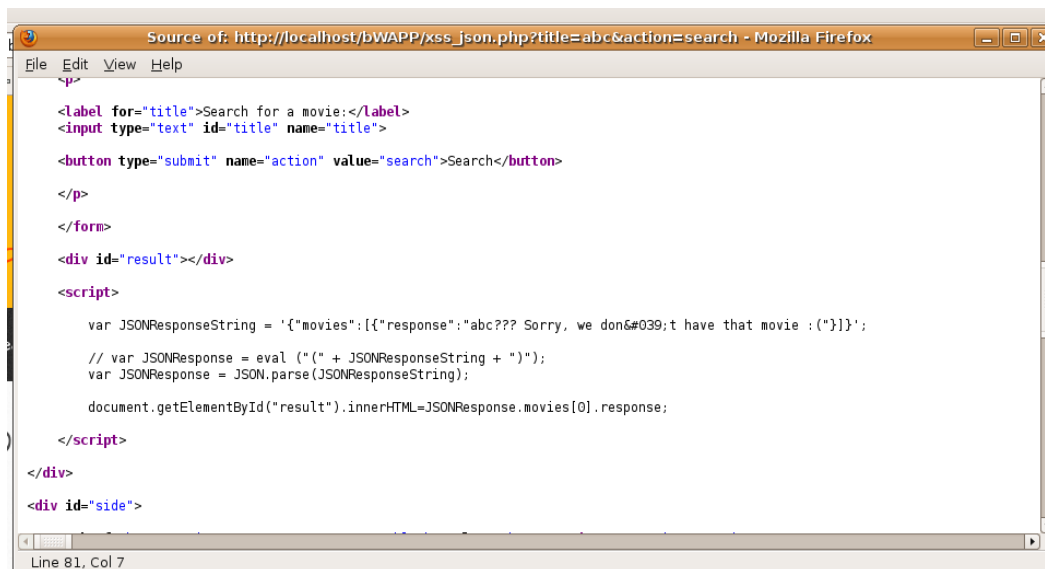


Figure 9 viewing the source of the page

So we can bypass it by just closing the current JavaScript statement and injecting new line of our malicious code. The payload is

`"}}';alert(1);</script>`